RELAZIONE TECNICA

Password Cracking con John the Ripper

Laboratorio didattico DVWA • SQL Injection e recupero password

Obiettivo dell'esercitazione

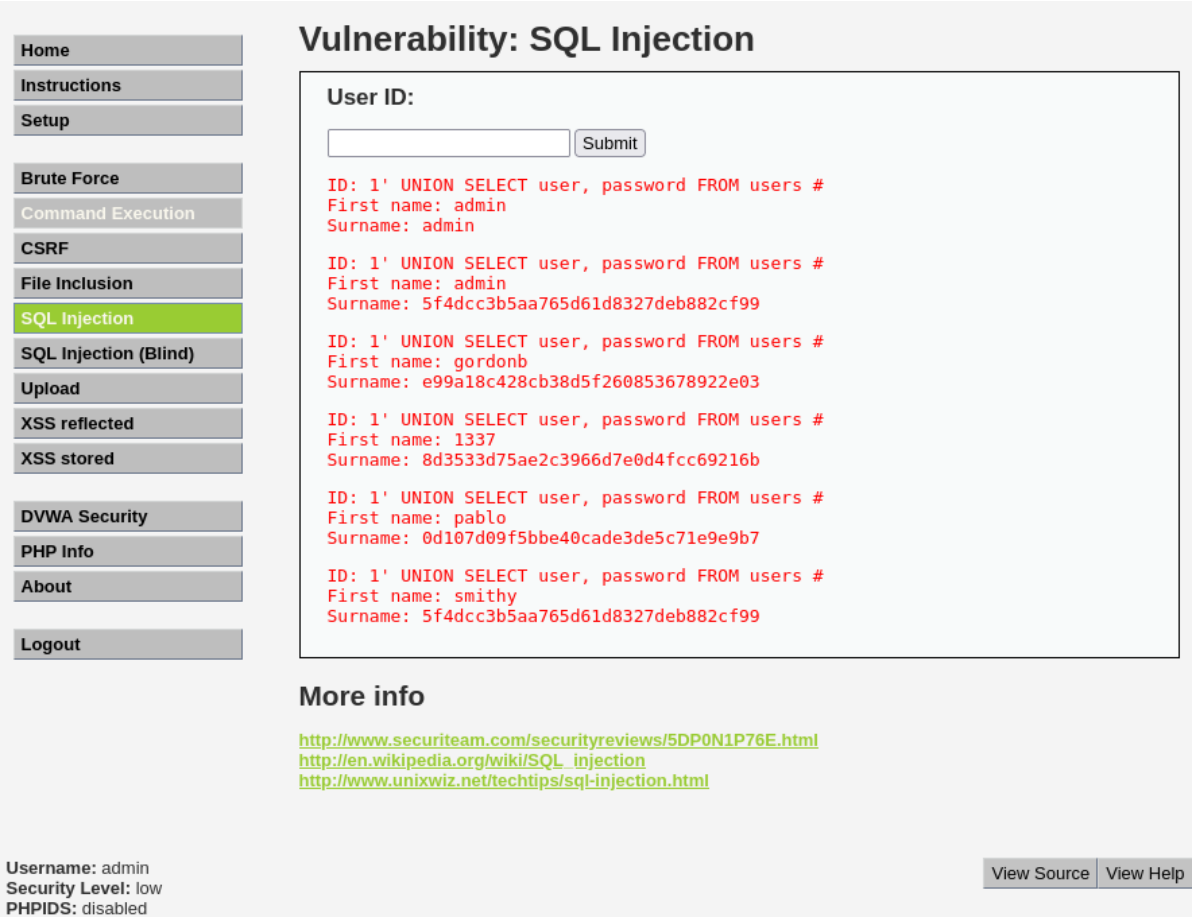
L'obiettivo è comprendere come gli hash delle password, recuperati nel laboratorio DVWA tramite SQL Injection, possano essere sottoposti a un tentativo di cracking offline con John the Ripper. L'attività è svolta in un ambiente didattico autorizzato e illustra i rischi di password prevedibili e di una gestione non adeguata delle credenziali.

Recupero dei dati tramite SQL Injection

Nel livello Low di DVWA è stata utilizzata una query UNION per leggere le colonne user e password della tabella users. La pagina ha restituito cinque record di prova. I valori della colonna password avevano 32 caratteri esadecimali, una forma compatibile con MD5, ma la lunghezza da sola non identifica univocamente l'algoritmo. Per il test è stato selezionato esplicitamente il formato Raw-MD5.

Payload utilizzato: 1' UNION SELECT user, password FROM users #

La vulnerabilità ha consentito di leggere dati non destinati alla visualizzazione. In un sistema reale, un'esposizione simile potrebbe facilitare ulteriori tentativi di compromissione degli account.

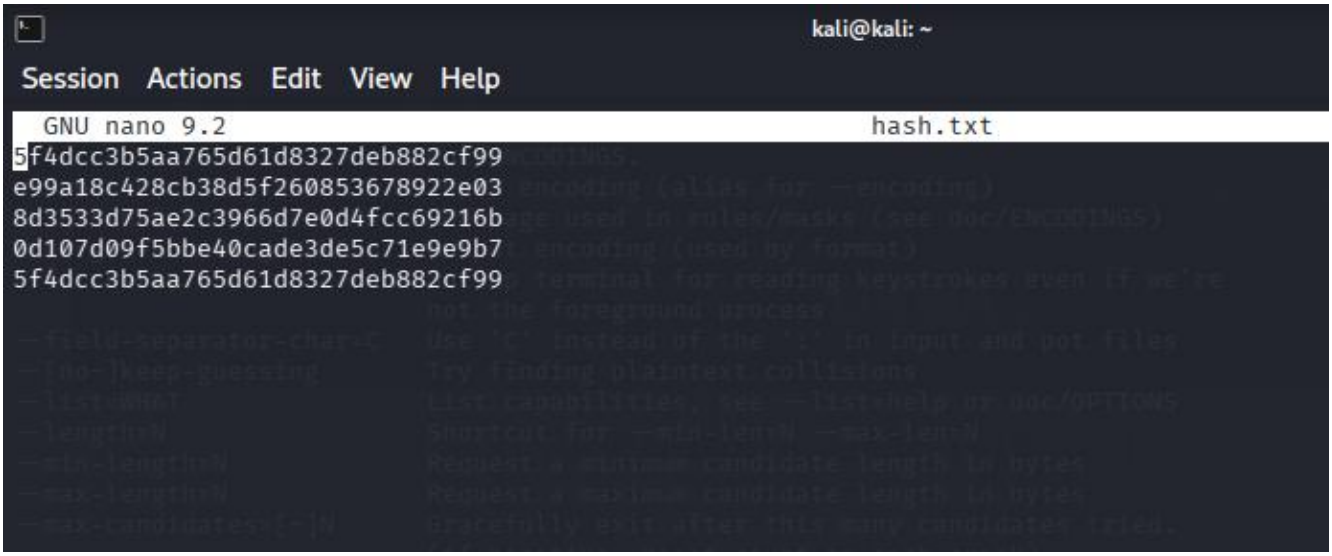


Risultato della SQL Injection in DVWA: utenti e valori della colonna password.

Preparazione degli hash

Gli hash sono stati inseriti nel file locale ~/hashes_dvwa.txt, uno per riga. Il file conteneva cinque righe; due righe riportavano lo stesso hash. Questo dettaglio è rilevante per interpretare il conteggio finale, perché una password identica può comparire più di una volta quando il medesimo hash è presente in più record.

La verifica dei formati supportati con john --list=formats ha mostrato Raw-MD5 e Raw-MD5u, confermando che la versione installata supporta il formato usato nell'esercitazione.



Metodo di cracking

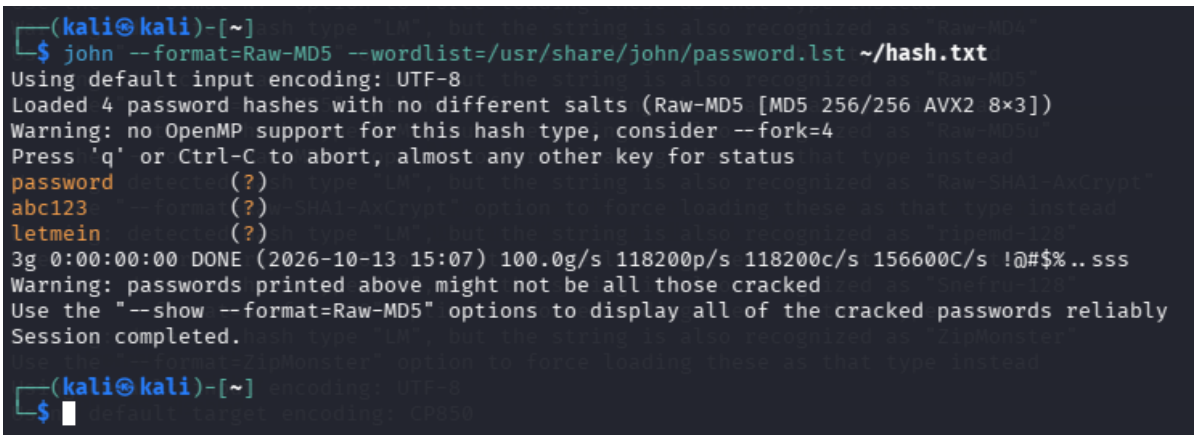
È stato utilizzato un attacco a dizionario (dictionary attack). John the Ripper legge le parole contenute in un dizionario, calcola per ciascuna il valore hash nel formato scelto e confronta i risultati con gli hash forniti. Se trova una corrispondenza, mostra la password candidata in chiaro. Il metodo è particolarmente efficace contro password comuni o prevedibili.

Comando eseguito:

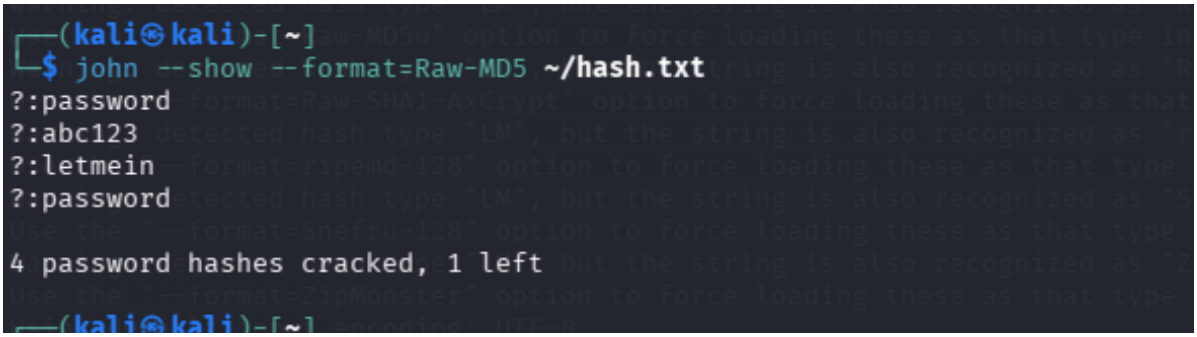
john --format=Raw-MD5 --wordlist=/usr/share/john/password.lst ~/hashes_dvwa.txt

Verifica finale:

john --show --format=Raw-MD5 ~/hashes_dvwa.txt



Esecuzione del cracking con John the Ripper e password individuate.



Output di john --show: riepilogo finale dei risultati.

Risultati

L'output finale mostra le password recuperate: password, abc123, letmein e password. La parola "password" compare due volte, coerentemente con la presenza di un hash duplicato nel file. John riporta "4 password hashes cracked, 1 left": quattro voci risultano recuperate e una voce resta non risolta.

Voce	Risultato
Formato selezionato	Raw-MD5
Righe nel file hash	5
Voci recuperate secondo john --show	4
Voci non recuperate	1
Password visualizzate	password; abc123; letmein; password

Gli screenshot non dimostrano l'associazione completa tra ciascuna password e ogni account; perciò la relazione non attribuisce password specifiche agli utenti senza un'ulteriore verifica.

Analisi e limiti

Il test dimostra che password deboli possono essere individuate rapidamente quando gli hash vengono esposti e si dispone di un dizionario adeguato. Non significa che ogni hash sia sempre recuperabile: una password lunga, casuale e assente dal dizionario può non essere trovata. Inoltre, la forma di 32 caratteri esadecimali è compatibile con MD5, ma non basta da sola a provarne l'origine.

Contromisure consigliate

- Correggere la SQL Injection usando query parametrizzate (prepared statements) e validazione degli input.

- Memorizzare le password con funzioni dedicate e lente, come Argon2id, scrypt, bcrypt o PBKDF2, usando un salt univoco.
- Impedire l'uso di password comuni e controllare le credenziali compromesse.
- Applicare il principio del minimo privilegio all'account database dell'applicazione.
- Ripetere i test dopo le correzioni e documentare le evidenze prima e dopo la remediation.

Conclusione

La pratica ha completato la sequenza dimostrativa: SQL Injection in DVWA, raccolta degli hash, selezione del formato Raw-MD5 ed esecuzione di un attacco a dizionario con John the Ripper. Il riepilogo finale riporta quattro voci recuperate e una non recuperata. L'attività evidenzia l'importanza di prevenire le SQL Injection e di non memorizzare le password con hash veloci e non progettati per la protezione delle credenziali.

Appendice — Evidenze

Gli screenshot inseriti sono quelli forniti durante l'esercitazione. I risultati descritti sono limitati a ciò che è visibile nelle schermate; non vengono dichiarati esiti ulteriori.